FIH

資訊安全管理白皮書

FIH 機密文件，禁止複製

簽 核 欄				
	核准 (APPROVED)	審核 (CHECKED)	製作 (PREPARED)	發行單位 (ISSUED BY)
製作單位				

※ ※ 本文件之著作權及營業秘密內容屬於 FIH,非經公司允許不得翻印 ※ ※

※ ※ 目　錄 ※ ※

1 目 的 6
2 範 圍 6
3 术語及定義 7
3.1 資訊安全(Information Security) 7
3.2 機密性(Confidentiality) 7
3.3 完整性(Integrity) 7
3.4 可用性(Availability) 7
3.5 資訊資產(Information Asset) 7
3.6 損失(Loss) 7
3.7 風險 (Risk) 7
3.8 威脅(Threat) 8
3.9 弱點 (Vulnerability) 8
3.10 風險評估(Risk Evaluation) 8
3.11 風險管理(Risk Management) 8
3.12 安全管制區域(Security Area) 8
3.13 資訊安全事件(Information Security Event) 8
3.14 資訊安全事故(Information Security Incident) 8
3.15 資訊安全管理(Information Security Management System ISMS) 8
3.16 適應性聲明(Statement of Applicability) 8
4 安全政策 9
4.1 資訊安全政策制定 9
4.2 資訊安全管理政策(文檔)體系 9
4.3 資訊安全政策之審核 10
4.4 資訊安全政策之發佈 10
4.5 資訊安全政策之評估 10
4.6 風險管理 10
5 資訊安全組織 11
5.1 資訊安全管理之責任組織 11
5.2 FIH 內部資訊安全事務協調機構 11
5.3 資訊處理設施的授權過程 12
5.4 保密協議 12

※ ※ 本文件之著作權及營業秘密內容屬於 FIH,非經公司允許不得翻印 ※ ※

5.5 與有關當局及特殊利益團體之聯繫 12
5.6 識別與相關團體有關的風險 12
5.7 應付客戶的安全處理 13
5.8 外部訪客之安全考量 13
5.9 獨立之資訊安全審查 13
6 資產管理 13
6.1 資產責任 13
6.2 資產分類分級指導原則 13
6.3 資訊資產分類 13
6.4 資產的擁有 14
6.5 資產的可接受使用 14
7 人力資源安全 14
7.1 聘僱前 14
7.2 聘僱中 15
7.3 聘僱的中止或變更 15
8 實體與環境安全 15
8.1 安全區域管制 15
8.2 設備安全 15
9 通訊與作業管理 16
9.1 設備作業程式與職責 16
9.2 第三方服務提供管理 16
9.3 系統規劃與驗收 16
9.4 惡意碼及行動碼的防範 16
9.5 資訊備份 17
9.6 網絡通信安全管制 17
9.7 媒體處理作業 17
9.8 資料或軟體交換作業 17
9.9 電子商務服務 18
9.10 監控 18
10 存取控制 18
10.1 使用者存取管制 18
10.2 網路存取之安全控制 19
10.3 作業系統、應用程式之存取管制 19

※ ※ 本文件之著作權及營業秘密內容屬於 FIH,非經公司允許不得翻印 ※ ※

10.4 行動式電腦作業與遠距工作 19
11 系統取得、開發與維護 19
11.1 系統安全需求 19
11.2 應用軟體系統之安全 19
11.3 加密控制措施 20
11.4 系統檔案之安全 20
11.5 開發和支援過程中的安全 20
11.6 技術脆弱性控制 20
12 資訊安全事故管理 20
12.1 報告資訊安全事件和弱點 20
12.2 資訊安全事故管理和改進 21
13 企業的永續經營 21
13.1 永續經營策略之規劃 21
13.2 永續經營策略之實施及測試 21
13.3 永續經營策略之審核 21
14 符合性 21
14.1 依從法律法規 22
14.2 安全政策與技术符合審核 22
15 **附件（另附）**

FIH 機密文件，禁止複製

※ ※ 本文件之著作權及營業秘密內容屬於 FIH,非經公司允許不得翻印 ※ ※

※ ※ 修 訂 履 曆 ※ ※

版次	ECN NO.	修 訂 內 容	備 注
A	BCG07-T91	初 版 發 行	共計 47 頁
B		修 訂 發 行	共計 23 頁
C		修 訂 發 行	共計 23 頁
D			
E			
F			
G			
H			
I			
J			
K			
L			
M			
N			
O			
P			
Q			
R			
S			
T			
U			
V			
W			
X			
Y			
Z			

FIH 機密文件，禁止複製

※ ※ 本文件之著作權及營業秘密內容屬於 FIH,非經公司允許不得翻印 ※ ※

1 目 的

本 FIH 公司《資訊安全管理白皮書》(以下簡稱“資安白皮書”)旨在提出 FIH 資訊安全管理的政策綱要，闡明 FIH 資訊安全管理的範圍和工作內容並採用品質管理模型：計劃、實施、監控、改善的持續不斷的品質改善流程，以實現“建立安全及可信賴之資訊作業環境，確保 FIH 電腦資料、系統、設備及網絡安全，保護 FIH 資訊資產的機密性、完整性、可用性、鑒別性與不可否認性，以保障公司業務永續經營”的資訊安全目標。

2 範 圍

本<<資訊安全管理白皮書>>係根據國際資訊安全標準 ISO/IEC 27001：2005，有效範圍覆蓋 FIH 公司所有類型的資訊以及產生、儲存、處理或傳輸資訊的設備、系統、網路等相關資產。

本<<資訊安全管理白皮書>>應用於所有 FIH 全球事業群(處)等單位內組織及組織內人員。

本<<資訊安全管理白皮書>>反映 FIH 公司爲建置信息安全管理體系所涉及的十一大工作要項：

(1) 安全政策

提出 FIH 資訊安全的目標、策略方針、指導原則，爲資訊安全提供管理指導和支援。

(2) 資訊安全組織

闡明 FIH 資訊安全管理單位的組織結構、任務、權責,以及爲保證公司資訊安全方面應採取的管理措施。

(3) 資產管理

闡明保護 FIH 重要資產所必須的資產分級分類原則與要求。

(4) 人力資源安全

闡明在員工就職前、就職中、與離職或轉職後所必要的管控及教育訓練措施以確保 FIH 資訊安全，減少人爲錯誤、偷竊 、欺詐或濫用設施的風險。

(5) 實體與環境安全

闡明爲保護 FIH 重要資訊、針對實體區域及設備之安全管控的原則與要求。

(6) 通訊與作業管理

闡明爲確保 FIH 資訊處理設備、網路及通信系統安全運作的指導原則與要求，包括 FIH 內部人員、第三方服務、系統規劃及驗收、上網管控、資訊備份、網路管理、媒體保存、資訊交換、電子商務及監控等。

(7) 存取控制

闡明爲確保 FIH 資訊的機密性及完整性，建立必要之資訊存取控制措施。

(8) 系統取得、開發與維護

闡明 FIH 資訊系統硬體及軟體的取得、建置、開發、維護的安全管控原則與要求。

※ ※ 本文件之著作權及營業秘密內容屬於 FIH,非經公司允許不得翻印 ※ ※

(9) 資訊安全事故管理

闡明 FIH 資訊安全事故發生後，處理之應變機制與改善方式。

(10) 企業的永續經營

闡明爲防止 FIH 網路及資訊系統作業中斷,保護關鍵/核心業務免受重大故障及災難影響,從而確保 FIH 業務永續而應建置的管控原則與要求。

(11) 符合性

闡明建置 FIH 資訊安全體系所依據的法律、法規及技朮標準、以及違反這些法律、法規及技朮標準可能導致的後果並針對資訊系統安全稽核的相關考量。

3 朮語及定義

3.1 資訊安全(Information Security)

所謂資訊安全係採用與資訊資產價值相稱及具有成本效益之管理、作業、技朮等安全防護手段、措施或機制，以確保組織內各項資訊資產免遭不當使用、洩漏、篡改、竊取、破壞等。

管理資訊安全，其最終目的在於維護關鍵資訊的機密性、完整性和可用性。

3.2 機密性(Confidentiality)

保證只有獲得授權的人才可以存取資訊。

3.3 完整性(Integrity)

保護資訊及處理方法的精確度、完整性，不容許未經授權之篡改。

3.4 可用性(Availability)

保證獲得授權的人能夠在需要時得以存取資訊及訪問相關設施。

3.5 資訊資產(Information Asset)

存在於任何形式，不論是有形的或是無形的，一旦遺失或受損對企業的永續經營都會造成損害的“有價值”的各類資訊相關的資產(可分類爲資訊、軟體、硬體、服務)。

3.6 損失(Loss)

資產可用性的限制，包含資產仍然存在，但是暫時不可用。

3.7 風險 (Risk)

受損害或者損失的可能性，導致負面結果的潛在因素。風險指這樣一種情況，其中一個人可能做一些意想不到的事情或者一個自然事件可能導致不希望的結果，從而產生負面的影響或者不良後果。

※ ※ 本文件之著作權及營業秘密內容屬於 FIH,非經公司允許不得翻印 ※ ※

3.8 威脅(Threat)

由於人爲的疏忽或故意，或者由於自然災害，而能夠非法存取、破壞、洩密、篡改資料或者阻斷服務式攻擊等，造成資訊資產損害的潛在的機會。

3.9 弱點 (Vulnerability)

資訊系統、系統規劃、管理控制、內部控制、實體或者物理設計中的缺陷，威脅可以利用其來獲得未授權存取，或者破壞處理過程。弱點有兩種基本類型：組織弱點和技术弱點。

3.10 風險評估(Risk Evaluation)

評估對於資訊和資訊處理的威脅、影響及弱點，以及它們發生的可能性。

風險評估是對下面因素的整體考量;

(1) 安全事故可能造成的商業損失。要把資訊和其他資產的保密性、完整性和可用性的損失的潛在後果也考慮進去。

(2) 對經常發生的危害採取預防性管理的作用下，這樣的危害實際發生的可能性。

3.11 風險管理(Risk Management)

以可以接受的成本，對可能影響資訊系統的安全風險進行鑒別、管控、減少或排除的管理過程。

3.12 安全管制區域(Security Area)

出於管控資訊安全的目的，而使用鎖、身份識別裝置、人工值守方式分隔的區域，例如通信、網路、資訊系統機房以及辦公區域等。

3.13 資訊安全事件(Information Security Event)

系統、服務或網路狀態經鑒別而顯示可能有違反資訊安全政策或保護措施失效，或可能與安全有關但事先未知狀況的發生。

3.14 資訊安全事故(Information Security Incident)

單一或一連串有顯著機率可能危害營運作業與威脅資訊安全 ,而不希望發生或非預期的資訊安全事件。

3.15 資訊安全管理(Information Security Management System ISMS)

整體管理系統的一部分，以營運風險方案爲基礎，用以建立、實施、操作、監督、審查、維持及改進資訊安全。

3.16 適應性聲明(Statement of Applicability)

描述組織資訊安全管理系統相關且適應之控制目標與控制措施的文件化聲明。

※ ※ 本文件之著作權及營業秘密內容屬於 FIH,非經公司允許不得翻印 ※ ※

4 安全政策

4.1 資訊安全政策制定

4.1.1 資訊安全目標

建立安全及可信賴之資訊作業環境，確保 FIH 電腦資料、系統、設備及網絡安全，保護 FIH 資料的機密性、完整性和可用性，以保障 FIH 業務永續經營。

4.1.2 資訊安全之策略方針

4.1.2.1 資訊安全、資訊流程系統化。

4.1.2.2 系統安全制度化，管制工具自動化。

4.1.2.3 資訊系統及資訊資產分類分級化，管制全面化。

4.1.3 資訊安全之指導原則

4.1.3.1 改善 FIH 資訊安全管理制度化程度，確保資訊系統整體運作模式不受個人因素影響。

4.1.3.2 將提供服務單位的管理功能及監督單位的稽核功能分開。

4.1.3.3 有效保護 FIH 所擁有的智慧財產權。

4.2 資訊安全管理政策(文檔)體系

4.2.1 資訊安全管理需要實現制度化，凡與資訊安全相關的事務都應被恰當地定義，並且使用書面文件體現其定義、規則、流程和作業記錄。

4.2.2 資訊安全管理政策(文件)體系的結構：上階文件是對下階文件的指導，下階文件是對上階文件的闡述、支援。

一階文件	FIH 資訊安全指導政策、總綱 設定整體資訊安控機制之目標，爲組織內各項資訊安控活動之政策與方向
二階文件	FIH 資訊安全組織與規範 依循一階文件安控方向，針對 FIH 資訊安全管理系統之各領域之控管項目制訂一般性標準
三階文件	FIH 資訊安全相關作業辦法、操作手冊、流程說明 依循二階文件安控標準，針對不同事業群（處）、系統與平臺制訂符合其系統或流程特性之管控規範
四階文件	資訊安全管制之相關記錄與表單 依據二階或三階文件之程式或標準，制訂申請/檢核文件，以留下資安管控方案運作記錄

※ ※ 本文件之著作權及營業秘密內容屬於 FIH,非經公司允許不得翻印 ※ ※

4.3 資訊安全政策之審核

4.3.1 資訊安全政策文件應由 FIH 資訊安全最高主管核准，並公佈傳達給 FIH 所有內部員工與相關外部人員。

4.3.1 資訊安全政策應定期或在有重大變更時加以審查，以確保資安相關政策之適當性、充分性及有效性。

4.4 資訊安全政策之發佈

4.4.1 FIH 資訊安全政策須經 FIH 最高資訊安全主管審核及批准後予以發行。

4.4.2 FIH 資訊安全政策爲 FIH 內部限制發行文件。

4.4.3 FIH 資訊安全管理部門(人員)及各單位人資部門(人員)、資訊管理部門(人員)、及各級主管負有向 FIH 全體員工、與 FIH 業務相關之外部人員進行宣導、教育訓練之責任。

4.5 資訊安全政策之評估

4.5.1 應每年定期對 FIH 各單位資訊安全管理體系進行獨立及客觀的評估，以反映 FIH 資訊安全管理政策、管理規範以及資訊安全技术之最新進展狀況，確保資訊安全之實務作業，確實遵守資訊政策，以及確保資訊安全實務作業之可行性及有效性。

4.5.2 資訊安全作業成果之評估以“資訊安全稽核”方式執行，將定期或不定期對各網路及資訊系統及資訊管理、應用之人員進行稽核。

4.5.3 “資訊安全稽核”可由 FIH 資訊安全管理單位或 FIH 外獨立資安稽核組織執行，以達到獨立、客觀的效果。

4.6 風險管理

4.6.1 定義風險評鑑方法

4.6.1.1 應鑑別風險評鑑方法，且可適合其資訊安全管理系統及已鑑別之營運資訊安全、法律與法規要求。

4.6.1.2 所選擇的風險評鑑方法應確保風險評鑑產生可比較的與可再產生的結果。

4.6.2 鑑別風險

4.6.2.1 應鑑別在資訊安全管理系統範圍內的資產和資產的擁有者。

4.6.2.2 應鑑別這些資產所受到的威脅。

4.6.2.3 應鑑別可能被這些威脅利用的脆弱性。

4.6.2.4 鑑別對資產失去機密性、完整性和可用性的衝擊。

4.6.3 分析與評估風險

4.6.3.1 應評鑑安全失效時可能對組織營運之衝擊，並將資產喪失機密性、完整性及可用

※ ※ 本文件之著作權及營業秘密內容屬於 FIH,非經公司允許不得翻印 ※ ※

性之後果列入考慮；

4.6.3.2 應根據與這些資產有關之威脅、脆弱性及衝擊，以及現行所實施的控制措施，評鑑安全失效實際發生的可能性

4.6.4 鑑別並評估風險處理之方式

4.6.4.1 應採用適當的控制措施。

4.6.4.2 若評估之風險明顯的在 FIH 可接受的範圍之內,則可在掌握狀況下客觀的接受此等風險，否則應盡量迴避風險或採取風險移轉的措施，如：保險公司，供應商。

4.6.5 應取得管理階層對所提議殘餘風險的核准。

4.6.6 應取得管理階層對實施和操作資訊安全管理系統的授權。

4.7 具體實作以附件 8《 FIH 數據備份管理辦法》，附件 7**《 ITOMS 文件控制程序》**爲標準結合 FIH IT 電子服務簽核平臺進行實施

5 資訊安全組織

5.1 資訊安全管理之責任組織

爲推展及稽核資訊安全各項工作，FIH 設置資訊安全管理組織，負責以下事務:

(1) 資訊安全政策、策略之訂定、宣導及執行監督。
(2) 資訊安全風險評估。
(3) 資訊安全責任之分配及協調。
(4) 資訊資產保護事項之監督。
(5) 資訊安全事件/事故之檢討及監督。
(6) 資訊安全教育訓練推動。
(7) 資訊安全稽核活動之實施。
(8) 其他資訊安全事務之辦理、執行。
(9) 資訊安全從業人員資安相關技術之認證。

5.2 FIH 內部資訊安全事務協調機構

爲協調推動 FIH 內部資訊安全各項工作，設置 FIH 內部之資訊安全事務協調機構，負責以下事務:

(1) 體系建置與監督:
協商制訂 FIH 資訊安全政策、規劃管理模式。推動、監督及檢核 FIH 資訊安全管理體系的建置與運作，爲實現 FIH 企業永續經營提供保障。

※ ※ 本文件之著作權及營業秘密內容屬於 FIH,非經公司允許不得翻印 ※ ※

(2) 資訊安全事務推動:

全面分析 FIH 及 FIH 各事業處資訊安全現狀，評估 FIH 及各事業處的資訊系統風險。追蹤、評估資訊科技的先進技术，充分考慮其先進性、實用性並推動其在 FIH 內的教育訓練及應用。

(3) 緊急應變處置:

推動資訊安全危機應變機制的規劃及建置，及資訊安全緊急事務應對體系和事務處理流程規劃及建置。

5.3 資訊處理設施的授權過程

當 FIH 內有新資訊處理設施上線之前應定義與實施管理階層授權過程。

5.3.1 新設備上線時· 使用者必須依照其使用之目的、範圍獲得，並確保所有資訊安全相關政策的符合。

5.3.2 硬體及軟體在上線時必須確認能與目前系統之相容· 避免造成因新系統的上線而影響其他系統的可用性。

5.3.3 所有內部或外部人員之私人資訊處理設備必須加以管控，以避免造成 FIH 內部系統的資安風險。

5.4 保密協議

所有接觸 FIH 機密資料之人員（包含內部員工及外部人員），應簽訂保密協議。協議中應包含資訊安全保密及相關強制規定。

5.4.1 應識別並定期評審反映 FIH 資訊保護需要的機密要求或保密協議內容。

5.4.2 保密協議使用可強制性的法律條款以表述 FIH 對機密資訊的保護需求。

5.5 與有關當局及特殊利益團體之聯繫

應與有關當局，特殊利益團體或其他專業人士、 資訊安全論壇、及專業協會等外界組織保持適當的聯繫。

5.5.1 當 FIH 網絡遭受外界攻擊時，可尋求外界之協助（如公安機關），以追查攻擊之來源，避免 FIH 網路繼續遭受攻擊。

5.5.2 當已定義之資安事故發生後，必須按照相關法律之規定及時的向有關當局及外界說明。

5.6 識別與團體有關的風險

※ ※ 本文件之著作權及營業秘密內容屬於 FIH,非經公司允許不得翻印 ※ ※

當 FIH 內組織將其全部的或者部分資訊系統、網路和作業環境的管理控制承包給 FIH 外部專業服務組織時。應當識別涉及外部團體營運過程的組織資訊及資訊處理設施的風險，並實施適當的控制措施。

5.7 應付客戶的安全處理

在給予客戶存取組織資訊或資產的權限之前，應處理所有已識別的安全要求。

5.8 外部訪客之安全考量

如果有外部訪客訪問的業務需要，應進行風險評估以確定安全隱患和管理對策，應考慮到所需的存取類型、資訊的價值、對第三方採取的管理措施和這種存取對 FIH 資訊的安全所造成的影響。 應建立一份正式的合同，這一合同應涉及所有的安全要求，以求符合公司的安全策略和安全標準。

5.9 獨立之資訊安全審查

FIH 之資訊安全政策（包括控制目標、控制措施、政策、流程及程式）應定期由資訊安委員會加以審查，以確保 FIH 相關資訊安全政策之品質。

5.10 具體實作以附件 9 《FIH 資訊安全政策與實施辦法》和附件 5 《FIH 資安事件處理作業辦法》爲標準結合 FIH IT 電子服務簽核平臺進行實施。

6 資產管理

爲保護 FIH 資訊安全，應建立資訊資產清冊加以分類分級，並訂定相對應之管制措施。

6.1 資產責任

6.1.1 應明確識別所有資產，並製作與維護所有的重要資產清冊。

6.1.2 與資訊處理設施相關的資訊及資產，其可接受使用的規則應予以識別、記錄。

6.2 資產分類分級指導原則

6.2.1 資訊必須做到分類分級。

6.2.2 應對現有資產按不同存在形態進行分類、依各種資產自身特性採取相應管控措施。

6.2.3 應對同一形態的資產類別依重要程度及價值分類，依重要層級採取相應保護措施。

6.2.4 應按照對於 FIH 的價值、關鍵程度和敏感性將資訊資產加以標識。

6.3 資訊資產分類

6.3.1 FIH 資訊資產分類，可根據工管、經管、生管、品管、人事、資訊、網絡、總務、安全管制等不同專業領域，依各專業領域對 FIH 資訊資產進行類別劃分。

※ ※ 本文件之著作權及營業秘密內容屬於 FIH,非經公司允許不得翻印 ※ ※

6.3.2 應納入分類的項目，包括：

(1) 資訊：資料庫、資料表、系統檔、使用者手冊、訓練教材、操作和支援規程、持續性計劃、書面報告、螢幕顯示、磁性媒體、電子訊息及檔案資料。

(2) 軟體：系統軟體、應用軟體、開發工具等。

(3) 實體：資訊設備(處理器、顯示器、筆記型電腦、數據機等)、通迅設備(路由器、交換機、傳真機、答錄機等)、儲存媒介(紙張、磁帶、光碟等)、機器設備、廠房、電力設備、空調設備、辦公設備等。

(4) 服務：電腦通迅服務、通用設施，例如消防、避雷、防水、防震、電力供應、空調服務等。

(5) 人員：應包括其相關經驗、資格、及技術等資料。

(6) 無形資產，包括企業形象與聲譽、公共廣告、業界成績。

6.4 資產的擁有

6.4.1 所有訊息及資產應該必須指定一名保管人，以進行該資產的維護、保管及保護。

6.4.2 應定期審查資產的分級分類及相關存取限制，以確保分級分類管控的正確性。

6.5 資產的可接受使用

6.5.1 所有訊息及資產的可接受使用原則必須被加以定義， 並以文件化加以維護。

6.5.2 所有訊息及資產的可接受使用原則必須涵蓋 FIH 內員工以及外部第三方人員。

6.6 具體實作以附件 10 《FIH 資訊資產分級分類辦法》和附件 11 《FIH 資訊類資產報廢作業細則》爲標準結合 FIH IT 電子服務簽核平臺進行實施。

7 人力資源安全

爲確保 FIH 之資訊安全，應將有機會接觸 FIH 資訊資產的人員，包括內部員工，約聘人員及外部第三方人員充分了解 FIH 相關資訊安全政策。

7.1 聘僱前

7.1.1 應根據 FIH 的資訊安全政策，規定員工、約聘人員和第三方用戶的安全角色和職責並形成正式的文件。

7.1.2 應根據相關的法律、法規和道德， 對所有的求職者， 約聘人員和第三方用戶進行背景及身份驗證檢查。該檢查應與業務要求、接觸資訊的類別以及風險相適宜。

7.1.3 受雇人員、承包商及第三方使用者應簽訂聘僱合約， 並將聘僱條件與限制視爲契約責

※ ※ 本文件之著作權及營業秘密內容屬於 FIH,非經公司允許不得翻印 ※ ※

任的一部分，聘僱合約應陳述上述人員本身與所屬組織對 FIH 資訊安全的責任。

7.2 聘僱中

7.2.1 管理者應要求所有的員工、約聘人員和第三方用戶按照 FIH 已建立的資訊安全政策和程式實施。

7.2.2 FIH 內的所有員工， 適當時，還應包括約聘人員和第三方用戶，應定期受到與其工作性質相關的適當的資訊安全教育訓練。

7.2.3 應建立一個正式的員工違反 FIH 資安政策的懲戒過程。

7.3 聘僱的中止或變更

7.3.1 應清晰規定和分配聘僱中止或變更的責任。

7.3.2 當聘僱、合同或協議中止或變更時，員工、約聘人員和第三方用戶應歸還所使用的 FIH 相關資產。

7.3.3 當聘僱、合同或協議中止或變更時，應撤銷所有員工、約聘人員和第三方用戶對資訊和資訊處理設備的訪問權限或根據變化調整。

8 實體與環境安全

8.1 安全區域管制

8.1.1 應當建立安全區域，把關鍵的和敏感的業務資訊處理設備放在安全區域，使其受到確定的安全範圍的保護，並有適當的人員進出管制。應當從實體上加以保護，減少無關人員進入安全管制區域的機會，以防止未經授權的存取並免於干擾和破壞。

8.1.2 應設計與應用保護措施以保護重要辦公區域及資訊處理設施，使其不受水災、洪水、地震、爆炸、民間運動、及其他自然或人爲災難的損害。

8.1.3 應控制收發裝卸區及其他未經授權人員可進入之公共區域，若可能，隔離資訊處理設施以防止未經授權的存取。

8.1.4 應建立實體的保護及相關控制措施以確保工作場所的安全。

8.1.5 針對公共區域應考慮相關之安全措施，以避免未經授權的資料存取。

8.2 設備安全

8.2.1 應當對設備安置、電力供應安全、電纜線安全、設備維護、場所外設備安全、設備處置及設備重複利用等活動制訂相應的管控措施，以防止資訊設施誤用、被竊取或災難

※ ※ 本文件之著作權及營業秘密內容屬於 FIH,非經公司允許不得翻印 ※ ※

而停止工作。

8.2.2 未經事前授權，與資訊處理設施相關的所有資訊及資產不應被帶至 FIH 所屬安全區域之外的地方。

8.3 具體實作以集團安全處之規定結合 FIH IT 電子服務簽核平臺進行實施

9 通訊與作業管理

9.1 設備作業程式與職責

9.1.1 應建立資訊處理設備操作、故障處理、備份、設備重啓及復原、設備和系統變更及發佈之標準作業流程。確保對設備、軟體和程式的操作及所有變更都得到嚴格的管理，並留下相對應的稽核軌跡。

9.1.2 爲降低可能的風險，應區分職務與責任範圍且分隔開發、測試、 及作業設施，以減少作業軟體或資料遭意外篡改或是遭未經授權的存取的風險。

9.2 第三方服務提供管理

9.2.1 應確保第三方實作、執行、及維護包含於第三方服務提供協議內的資訊安全控制措施、服務定義及提供等級。

9.2.2 應定期監控與審查由第三方提供的服務、報告、及記錄，並定期實行稽核。

9.2.3 考慮牽涉到營運系統及過程的重要性與重新評鑑的風險，應管理服務條款的變更，包括維護及改善現存的資訊安全政策、流程、及控制措施。

9.3 系統規劃與驗收

9.3.1 資訊系統的使用應監控、調校、 及預估未來容量需求，以確保所需的系統效能及降低系統錯誤之風險。

9.3.2 應建立對新資訊系統、 系統升級及新版本的驗收準則，且開發期間與驗收前應完成適當之系統測試。

9.4 惡意碼及行動碼的防範

9.4.1 FIH 應統籌建置全面的電腦病毒及惡意軟體的監測和防禦及復原系統，並針對使用者進行相關認知的教育訓練。

9.4.2 應建立有效管控網路使用者上網行爲之方法，避免因瀏覽網站，所帶來感染惡意碼的

※ ※ 本文件之著作權及營業秘密內容屬於 FIH,非經公司允許不得翻印 ※ ※

風險。

9.4.3 授權使用者使用行動碼時，應確保授權的行動碼依據清楚定義的資訊安全政策作業，並應阻止執行未經授權的行動碼。

9.5 資訊備份

9.5.1 應根據資訊的重要等級及風險評估的結果制定資訊備份策略並定期執行備份資料的恢復性測試。

9.5.2 應根據相關之法令需求，保留必要之資訊備份媒體。

9.6 網絡通信安全管制

9.6.1 應建置統籌考慮的網際網路安全管制系統，給使用者提供有區別的上網服務，並且對使用者的上網行爲予以記錄，以實現對於使用者利用網際網路的管控。

9.6.2 應讓所有員工了解 FIH 上網及通訊網路政策。

9.6.3 應制訂相關管理政策、作業手冊等，以提供對於網路安全規劃、網路服務、網路使用者管理、主機安全防護、防火牆、無線網路通訊之安全管理、軟體配置與許可權控制、網路資訊之管理等網路作業的原則。

9.6.4 應統籌建置制訂針對通信安全管理的政策。

9.7 媒體處理作業

9.7.1 應制訂針對可移動的資訊存儲介質和紙質文件的管理制度。

9.7.2 儲存機密性及敏感性資料的資訊處理媒體，當不再繼續使用時，應使用正式安全穩固的報廢方式程序。

9.7.3 應建立資訊的處理及存儲程序，以保護資訊不被未經授權的洩漏和誤用。

9.7.4 應保護系統文件，避免未經授權的存取。

9.8 資料或軟體交換作業

9.8.1 FIH 與其他組織間進行資料或軟體交換，應訂定正式的協議，將機密性及敏感性資料的安全保護事項及有關人員的責任列入。

9.8.2 對於電子商務應用、自動辦公系統等資訊交換作業，應采取特別的安全保護措施，以防止未經授權的資料存取及篡改、外洩。

9.8.3 應建立針對對外聯繫的系統如：電子郵件、FTP 傳輸、即時通訊及上網等管控系統，建立有效稽核軌跡，阻止敏感資料外洩，降低 FIH 資訊安全風險。

※ ※ 本文件之著作權及營業秘密內容屬於 FIH,非經公司允許不得翻印 ※ ※

9.8.4 針對實體的儲存媒體的運輸，應建立相關及有效之保護措施。

9.9 電子商務服務

9.9.1 應保護在公用網路上傳輸涉及電子商務的資訊，使不受欺詐行爲、合約爭議、及未經授權的揭露與修改。

9.9.2 應保護涉及線上交易的資訊，以防止不完整的傳輸、錯誤的路由、未經授權的資訊交換、未經授權的揭露及未經授權的訊息複製或重送。

9.9.3 應保護在公眾開放系統上可取得資訊的完整性，以防止未經授權的修改。

9.9.4 應確保電子商務服務之可用性，避免因系統中斷所產生的損失。

9.10 監控

9.10.1 應產生與保持一段期間的稽核日誌，以記錄使用者活動、 異常狀況、錯誤及資訊安全事件， 以協助未來的調查與存取控制監控。

9.10.2 應建立監控資訊處理設施使用的程序，並定期審查監控活動的結果。

9.10.3 應記錄及保護系統管理員與使用者的活動日誌。

9.10.4 應針對失誤日誌進行分析及採取適當行動，避免類似事件再次發生。

9.10.5 FIH 所有相關資訊處理系統的時鐘應與公認的準確時間來源同步，以保證稽核日誌的正確性。

9.11 具體實作以附件 1 《FIH AD 管理手冊》，附件 3 《FIH 帳號管控作業細則》，附件 4《日志收集作業細則》，附件 6 《防病毒軟件(諾頓)升級作業細則》爲標準結合 FIH IT 電子服務簽核平臺進行實施。

10 存取控制

10.1 使用者存取管制

10.1.1 應建立使用者帳號設定、權限審核、密碼管理、及特權管理之標準作業流程。

10.1.2 應建立對於帳號的管控，以在人員調動、離職時，即時對帳號進行動態管理。

10.1.3 應讓使用者瞭解其所應付的相關責任及相關風險。

10.1.4 應制訂資訊處理設備及文件的螢幕及桌面淨空政策，避免未經授權的訪問以保護 FIH 的機密資訊。

※ ※ 本文件之著作權及營業秘密內容屬於 FIH,非經公司允許不得翻印 ※ ※

10.2 網路存取之安全控制

10.2.1 應明確規定向使用者提供的網路服務之限制，以及使用者使用何種強制性的通道，以減少未經授權的存取系統或電腦設施之風險。

10.2.2 應明確制定有關外部使用者及網路設備的身份監別、網絡分隔、網絡連線作業、網路路由等控制的規範。

10.2.3 針對遠端診斷埠及遠端控制之軟體，應建立安全之管控，避免未經授權的存取。

10.3 作業系統、應用程式之存取管制

10.3.1 應明確制訂有關作業系統、應用程式的登入程式、使用者身份鑒別及識別、終端設備作業時間限制、連線作業時間、連線終止、密碼管控之控制的規範，以防止對於作業系統的未經授權的存取。

10.3.2 對重要作業系統、應用程式的存取，應建立日誌及行爲記錄，以利日常監控及事件稽核。

10.4 行動式電腦作業與遠距工作

10.4.1 應制定正式政策及採取適當的安全措施，以防止使用行動式電腦與通訊設施存在的風險。

10.4.2 應制定與實施還距離作業的資訊安全管控措施（如使用 SSL VPN）。

10.5 具體實作以附件 1《 FIH AD 管理手冊》，附件 2《 FIH Devicelock 管控作業辦法》，附件 3《FIH 帳號管控作業細則》爲標準結合 FIH IT 電子服務簽核平臺進行實施

11 系統取得、開發與維護

11.1 系統安全需求

11.1.1 新開發之資訊系統，或是現有系統功能之強化、升級，皆應明定資訊安全需求，將系統安全需求納入系統功能。

11.1.2 凡開發設計之新系統除系統自身之安全(包含軟體和硬體設施)外，對開發之過程也必須制定詳細管控制作業規範。

11.2 應用軟體系統之安全

11.2.1 應當把適當的管理措施和查驗追蹤或者活動日誌設計到應用軟體系統中，以防止在應用軟體系統中的使用者資料的遺失、異動或者誤用。

※ ※ 本文件之著作權及營業秘密內容屬於 FIH,非經公司允許不得翻印 ※ ※

11.2.2 應建立驗証資料輸入、處理及輸出時正確性及及完整性的作業流程。

11.3 加密控制措施

11.3.1 應制定與實施密碼控制措施以保護機密資訊。

11.3.2 應有金鑰管理以支援在整個 FIH 內統一使用密碼技術。

11.4 系統檔案之安全

11.4.1 爲確保 IT 專案和支援行爲以安全的方式進行，應建立正式的控制程式，對作業軟體、系統測試資料和系統源代碼、程式資料庫的使用或存取加以管控，以保証系統檔案的安全。

11.5 開發和援援過程中的安全

11.5.1 系統變更的實施應使用正式變更控制程序予以控制。

11.5.2 作業系統變更時，應審查與測試重要營運應用系統，以確保對 FIH 的 IT 運作無不利的衝擊。

11.5.3 應阻止修改套裝軟體，如有必要的變更，應嚴格控制所有的修改。

11.5.4 應採取必要的安全措施以避免資訊洩漏的機會。

11.5.5 應監督與監控軟體開發委外。

11.6 技術脆弱性控制

11.6.1 應取得關於使用中資訊系統的技術脆弱性之相關資訊，評估 FIH 對於該脆弱性暴露存在的風險以及採取適當的控制措施，以預防與處理可能產生的風險。

11.7 具體實作以 FIH IT 電子服務簽核平臺進行具體實施

12 資訊安全事故管理

12.1 報告資訊安全事件和弱點

12.1.1 應當建立正常的資訊安全事件報告、應答和分類機制，在接到資訊安全事件報告後著手採取措施。應該建立資訊安全事件處理小組，確保整個 FIH 都知道此處理小組，並確保處理小組能夠及時的應答。

12.1.2 應要求所有的員工、約聘人員和第三方用戶注意並報告系統或服務中已發現或疑似的安全弱點。

※ ※ 本文件之著作權及營業秘密內容屬於 FIH,非經公司允許不得翻印 ※ ※

12.2 資訊安全事故管理和改進

12.2.1 應建立管理職責和程式，快速、有效和有序的處理資訊安全事件。

12.2.2 應有適當的機制使資訊安全事件的類型、 數量、及成本能夠被量化與監控。

12.2.3 應從過去的資安事故中學習，建立相關的管控措施，避免事故的再次發生。

12.2.4 應建立資安事故發生後證據蒐集的處理流程，包含證據蒐集、證據保存及提供法庭，維護證據的有效性。

12.3 具體實作以《FIH 資安事件處理作業辦法》爲標準進行實施

13 企業的永續經營

13.1 永續經營策略之規劃

13.1.1 指定適當層級主管負責永續經營政策之執行與協調。

13.1.2 分析造成業務停擺的可能危機及損失。

13.1.3 定期作風險評估並調整永續經營政策。

1322 永續經營策略之實施及測試

13.2.1 評價所有 FIH 業務及資訊的完整性和正確性。

13.2.2 執行有關保護的措施。

13.2.3 定期更新永續經營管理方法。

13.2.4 定期演練與修正緊急應變計劃。

13.2.5 預防風險：必須定期評估風險並進行風險管理，以確保組織隨時都在妥善的保障之下。

1333 永續經營策略之審核

13.3.1 永續經營策略必須配合業務、組織及人員之變更而定期更新。

13.3.2 建立資訊安全事件之通報作業流程及應變措施。

13.3.3 訂立緊急應變計劃：緊急應變計劃應定期演練與修正、緊急應變計劃程式與流程書面化、緊急應變計劃納入內部教育訓練。

14 符合性

本<<FIH 資訊安全管理白皮書>>依據國際標准化組織(ISO)等同采納英國標准協會(British Standard Institute)資訊安全標准 BS7799 而制訂的 ISO/IEC17799：2005 資訊安全國際標準，並結合 FIH 公司資訊安全現狀和目標而訂定。

※ ※ 本文件之著作權及營業秘密內容屬於 FIH,非經公司允許不得翻印 ※ ※

14.1 依從法律法規

14.1.1 對與 FIH 相關的法令、規章要求，FIH 都必須進行識別。所識別之法規不僅局限於本國或地區的法律法規，與 FIH 業務活動有關的其他國家或地區的法律法規亦應被識別。此部分可與 FIH 法務部門或外部法律顧問獲得有關建議。對已識別出之法律法規，FIH 應對其中相關規定明確化、文檔化，以確保 FIH 之規定對相關法律及法規之符合性。

14.1.2 FIH 注重智慧財產權之維護。

14.1.3 FIH 注重個人隱私權之維護。

14.1.4 FIH 注重防止資訊處理設備濫用。

14.1.5 不同行業，不同國家或地區對加密技术都有不同之規定。在加密資訊進行傳遞時要遵循相關法律建義。

14.1.6 在處理資訊安全相關事務時，應注意証據收集之合法性。

14.2 安全政策與技术符合性審核

14.2.1 FIH 資訊安全管理單位應定期對 FIH 安全政策實施狀況進行內部稽核。FIH 資訊安全管理單位可依據審核結果對安全政策內容進行修改。

14.2.2 FIH 亦可通過公正、獨立之第三方認証機構之審核，獲取相關資訊安全之証書，如 ISO/IEC27001 認証或外部稽核報告，以提升 FIH 競爭力。FIH 資訊安全管理單位可依據審核結果對安全政策內容進行修改。

14.2.3 對於 FIH 所採用資訊安全之技术，FIH 資訊安全管理部門亦應定期對其可行性、符合性、適當性進行審核。對於資訊技术之審核，可由內部資訊安全管理人員進行，如有必要亦可委託第三方技術組織或人員進行。可與上述管理性審核同步，亦可獨立進行。FIH 資訊安全管理單位可依據審核結果對資訊安全之技術進行修改。

※ ※ 本文件之著作權及營業秘密內容屬於 FIH,非經公司允許不得翻印 ※ ※

※ ※ 控制變更頁 ※ ※

編號	變更主旨	變更日期	變更工作量	變更人	核准人